

Reducing Data Risk in Everyday GenAI Use

AI use at work has nearly doubled in two years, and most of it runs through three doors: public tools, Copilot, and whatever third-party app someone just connected. This session maps those doors and what to put on each one.



Presenters: Dave Barnett and Itir Clarke, Proofpoint

- 01 Adoption is outrunning governance
- 02 Three doors GenAI walks through
- 03 The most common adoption pattern
- 04 Risk, by surface
- 05 Recommendations, by surface
- 06 Two risks in the wild
- 07 A maturity model to self-score against

QUICK RECALL

Every GenAI risk in this session runs through one of three doors: public tools, Copilot for M365, or a connected app. Govern each door differently; don't just block them.

Adoption is outrunning governance

Gallup finds regular AI use among U.S. workers has nearly doubled since 2023: daily use is up from roughly 4% to 8%, weekly-or-more use from about 11% to 19%, and yearly-or-more use from around 21% to 40%. The European Commission's October 2025 report on platformisation of work puts it at 1 in 3 EU workers using AI tools already, mostly for writing, translation and data processing, with adoption highest in Northern and Central Europe. BCG's research goes further: it finds APAC frontline employees notably ahead of the global pace, using GenAI regularly well above the worldwide average, and using AI at least weekly at a materially higher rate than the rest of the world.

Usage is climbing faster than governance can follow, and the numbers on risk back that up:

78%

of organizations use AI in at least one business function

McKinsey, The State of AI

73%

of organizations have had at least one negative consequence from GenAI

McKinsey, The State of AI

13%

of employee GenAI prompts include sensitive data

Lasso research

Three doors GenAI walks through

Part of the governance gap is sheer scale: the directory "There's An AI For That" now lists over 42,000 AI tools covering 12,000-plus tasks and 5,000-plus jobs, with over 6,400 tools in the business category alone. No security team is vetting that catalog one tool at a time, which is why the tension the session keeps returning to is a simple trade-off: use more AI, or hold to an acceptable level of risk. In practice, nearly all of that exposure arrives through three doors:

Public GenAI tools

ChatGPT, Gemini, Claude and the like, used directly with no sanctioning or integration.

Copilot for Microsoft 365

Sanctioned, but inherits whatever access and oversharing already exists across SharePoint and the rest of M365.

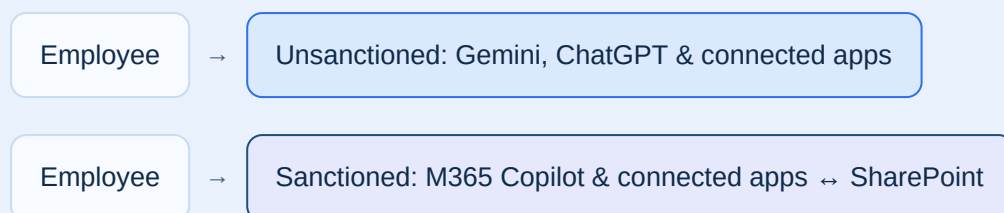
Apps connected to AI

Third-party and custom apps wired into GenAI, often with permissions nobody's reviewed.

Asked to name their top concerns, the room's answers lined up neatly with those three doors, plus two that cut across all of them: data leakage into public tools, oversharing exposed by Copilot, ungoverned connected apps, sensitive data ending up in AI training sets, and data access or exfiltration by AI agents acting on someone's behalf.

The most common adoption pattern

Most organizations aren't building custom AI. They're connecting commercial tools with minimal integration, Microsoft Copilot to draft documents, GitHub Copilot to review code, and the result is a fork in how each employee's request gets handled:



The unsanctioned path raises one set of questions: how do you make sure people only use trusted apps and don't hand organizational data to untrusted ones, and how do you make sure they're using approved GenAI apps securely in the first place? The sanctioned path raises a different one: once Copilot can retrieve anything from SharePoint, how do you know what data it's touching, and how do you restrict or redact what it's allowed to surface?

Risk, by surface

Focused on public and commercial GenAI specifically, four risk patterns keep recurring, and each one feeds the same set of consequences: data exfiltration and security breach, overprivileged access to sensitive data, compliance violations, and a wider attack surface.

Shadow AI

Employees use unsanctioned GenAI apps for work tasks without IT or Security knowing, potentially disclosing sensitive information straight to an AI vendor.

Excessive permissions

Employees accumulate more access than their daily work needs, and GenAI apps inherit that same broad access.

Supplier risk

The security posture of an unvetted GenAI tool is often unknown. If that vendor is breached, your data can go with it.

Misconfiguration

Misconfigured GenAI apps or the platforms hosting them add vulnerabilities that go unnoticed until something exploits them.

Recommendations, by surface

The fix isn't to block everything, it's to govern each surface on its own terms.

☒ Public tools ☒ Copilot ☒ Connected apps

[Collapse all](#)

- **Public GenAI tools**

PUBLIC

Don't just block access outright. Consider exceptions at the individual or business-unit level, and actively monitor usage while educating staff and applying DLP policies consistent with existing infosec policy.

- **Copilot for Microsoft 365**

COPILOT

Classify and label content to strengthen access governance, guide users to fix oversharing, classify and label Copilot's output, alert on possible misuse, and keep a curated, indexed list of SharePoint sites it's allowed to draw from.

- **Connected GenAI & GenAI-enhanced apps**

CONNECTED APPS

Discover which third-party apps are connected to your collaboration platforms, monitor how AI is using sensitive data, block unauthorized training or fine-tuning on that data, and map your data assets against whatever compliance framework applies.

One product-level example that came up: AI-driven classifiers that auto-learn the content classes unique to an organization, then use that to remediate oversharing and drive DLP policy, rather than relying on generic, pre-built categories.

Two risks in the wild

The proprietary code, pasted into ChatGPT

Public GenAI tools

John Normand, a developer at a fictional investment firm, is tasked with clearing security vulnerabilities from the firm's proprietary stock-picking algorithm. To get help fast, he pastes the source file straight into ChatGPT and asks it to review the code for vulnerabilities, handing a public AI vendor the company's core IP along with the request.

The self-service portal that walked straight to OneDrive

Connected & agentic apps

A legal and e-discovery lead asks an AI app builder to create a self-service portal for financial reports. The tool happily connects directly to her personal OneDrive, where those reports actually live, and starts building against it. Nobody reviewed that connection or the data it now touches, which is exactly how ungoverned, AI-driven app development turns into sensitive data exposure.

A maturity model to self-score against

The session closed with a sample data security maturity framework for GenAI, scored 1 to 5 across six dimensions. A sample organization landed at an average of 3.67, strongest on enterprise coverage and weakest on metrics, which is a fairly typical shape: the tooling gets deployed before anyone builds the dashboards to prove it's working.

DIMENSION	SCORE	WHAT IT COVERS
Enterprise coverage	5.0	Multi-channel DLP/DSPM tools, classifying data at rest, monitoring activity, enforcing controls like justification, redaction and blocking.
Security awareness & training	4.0	Individual or department-level exceptions tied to training, regular updates, clear communication channels.
Security governance	4.0	Cross-functional stakeholders, regular communication, policy review, a working feedback mechanism.
Incident management	3.5	A documented incident response plan, regular IR testing, an operational team structured for proactive response.
Policy & procedures	3.0	Clear objectives and scope, compliance checks, audits, DLP policies, defined user roles.
Metrics	2.5	Incident metrics, response times, regular reporting, dashboards.

Used as a self-assessment, the six dimensions are a reasonable proxy for whether a GenAI program is governed or just deployed. Score each one honestly before treating any of the recommendations above as done.